

Vulnerability Assessment Report

Submitted by Sneha K

This report documents the results of a local web application assessment conducted on a virtual machine environment provided during the cybersecurity bootcamp challenge. The objective was to identify potential vulnerabilities, misconfigurations, and outdated components within the hosted web server environment accessible via `127.0.0.1:8081`.

The assessment was performed using **Windows PowerShell** for reconnaissance and enumeration. The findings indicate multiple security weaknesses, including version disclosure, exposed directories, and the presence of outdated software.

Host Machine: Windows 10

Target System: Virtual Machine (OVA) running Apache server

Purpose: Local vulnerability assessment of hosted web application

Methodology

The assessment followed a systematic approach to identify running services, accessible directories, and potential vulnerabilities.

Step 1: Checking Active Ports

netstat -ano | findstr :8080

- Purpose: To verify which process is listening on port 8080/8081.
- Result: The port `127.0.0.1:8080` (and later 8081) was found in the **LISTENING** state, confirming the presence of an active local web service.

```
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

Try the new cross-platform PowerShell https://aka.ms/pscore6

PS C:\Users\user> nmap -p- 127.0.0.1
nmap : The term 'nmap' is not recognized as the name of a cmdlet, function, script file, or operable program. Check
the spelling of the name, or if a path was included, verify that the path is correct and try again.
At line:1 char:1
+ nmap -p- 127.0.0.1
+ ~~~~~
+ CategoryInfo          : ObjectNotFound: (nmap:String) [], CommandNotFoundException
+ FullyQualifiedErrorId : CommandNotFoundException

PS C:\Users\user> netstat -ano | findstr :8080
TCP    127.0.0.1:8080      0.0.0.0:0          LISTENING        11408
PS C:\Users\user>
```

Step 2: Accessing the Local Web Application

- Navigated to `http://127.0.0.1:8081/` using a web browser.
- The page displayed an **Index of /** directory listing, exposing several directories:
 - `/chat/`
 - `/drupal/`
 - `/payroll_app.php`
 - `/phpmyadmin/`

Finding: Directory listing is enabled, which can expose sensitive files and internal structure.

```
<  →  ↻  127.0.0.1:8081  ☆  🔴
📑 | 🔍 Introduction to Aer... | 📶 NPTEL | 📶 NPTEL | 📶 Telegram Web | 📶 (2) WhatsApp | 📶 CEE Kerala | 📶 Read A Terribly Stra... | 📶 Chapter2.pdf | 📁 All Bookn

Index of /

  Name      Last modified   Size Description
-----
📁 chat/    2020-10-29 19:37 -
📁 drupal/  2011-07-27 20:17 -
📄 payroll_app.php 2020-10-29 19:37 1.7K
📁 phpmyadmin/ 2013-04-08 12:06 -

Apache/2.4.7 (Ubuntu) Server at 127.0.0.1 Port 8081
```

Step 3: Service Enumeration using curl

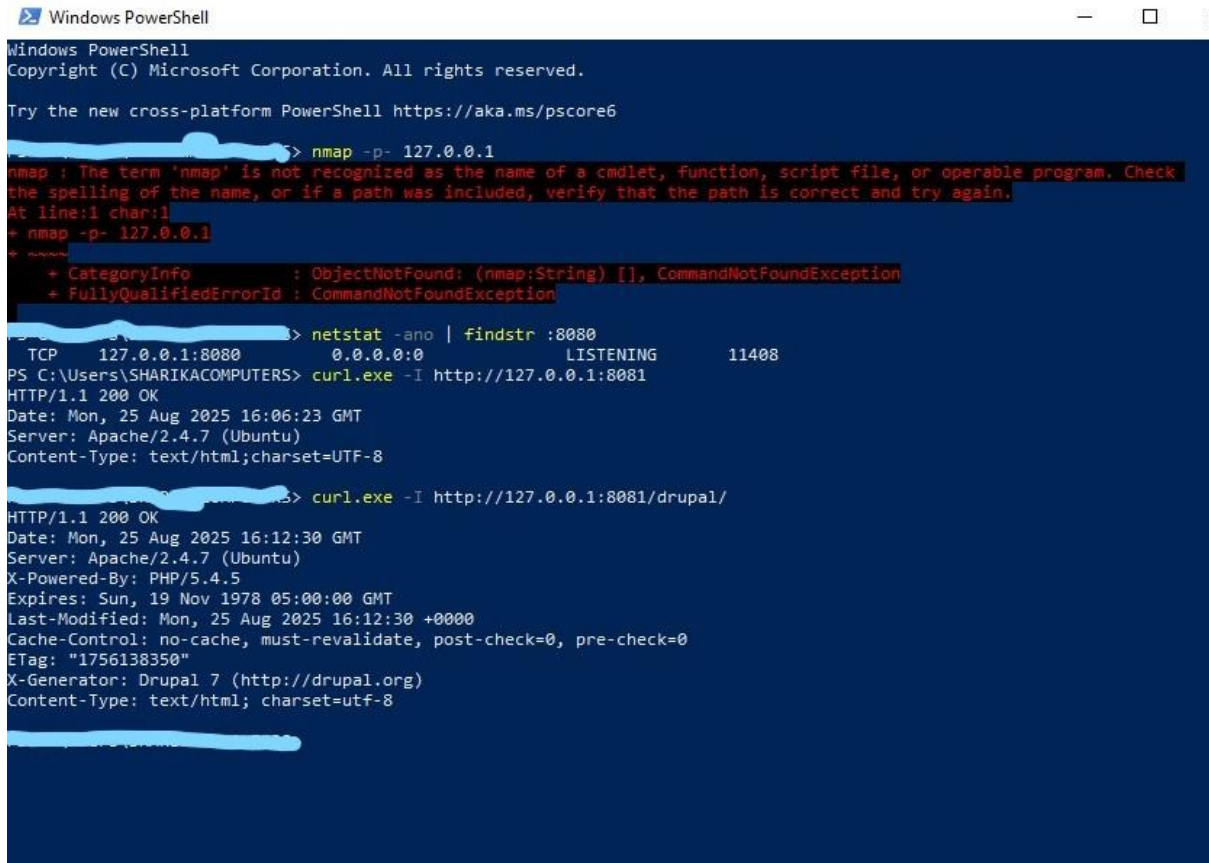
Example commands used:

```
curl.exe -I http://127.0.0.1:8081
```

```
curl.exe -I http://127.0.0.1:8081/drupal/
```

- The server responded with headers revealing:
 - Server: Apache/2.4.7 (Ubuntu)
 - X-Powered-By: PHP/5.4.5
 - Generator: Drupal 7 (http://drupal.org)

Finding: Version disclosure for Apache, PHP, and Drupal, indicating outdated components vulnerable to known exploits.



```
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

Try the new cross-platform PowerShell https://aka.ms/pscore6

PS C:\Users\SHARIKACOMPUTERS> nmap -p- 127.0.0.1
nmap : The term 'nmap' is not recognized as the name of a cmdlet, function, script file, or operable program. Check the spelling of the name, or if a path was included, verify that the path is correct and try again.
At line:1 char:1
+ nmap -p- 127.0.0.1
+ ~~~~~
+ CategoryInfo          : ObjectNotFound: (nmap:String) [], CommandNotFoundException
+ FullyQualifiedErrorId : CommandNotFoundException

PS C:\Users\SHARIKACOMPUTERS> netstat -ano | findstr :8080
TCP        127.0.0.1:8080      0.0.0.0:0          LISTENING   11408
PS C:\Users\SHARIKACOMPUTERS> curl.exe -I http://127.0.0.1:8081
HTTP/1.1 200 OK
Date: Mon, 25 Aug 2025 16:06:23 GMT
Server: Apache/2.4.7 (Ubuntu)
Content-Type: text/html; charset=UTF-8

PS C:\Users\SHARIKACOMPUTERS> curl.exe -I http://127.0.0.1:8081/drupal/
HTTP/1.1 200 OK
Date: Mon, 25 Aug 2025 16:12:30 GMT
Server: Apache/2.4.7 (Ubuntu)
X-Powered-By: PHP/5.4.5
Expires: Sun, 19 Nov 1978 05:00:00 GMT
Last-Modified: Mon, 25 Aug 2025 16:12:30 +0000
Cache-Control: no-cache, must-revalidate, post-check=0, pre-check=0
ETag: "1756138350"
X-Generator: Drupal 7 (http://drupal.org)
Content-Type: text/html; charset=utf-8
```

Step 4: Drupal Version Verification

```
curl.exe -I http://127.0.0.1:8081/drupal/CHANGELOG.txt
```

- The changelog file was accessible and confirmed **Drupal 7** as the installed version.

Finding: Exposed CHANGELOG file confirms outdated CMS version (Drupal 7) — known for multiple critical vulnerabilities such as SQL injection (CVE-2018-7600 “Drupalgeddon 2”).

```

C:\Users\user> curl.exe -I http://127.0.0.1:8081/drupal/CHANNELOG.txt
HTTP/1.1 404 Not Found
Date: Mon, 25 Aug 2025 16:15:39 GMT
Server: Apache/2.4.7 (Ubuntu)
Content-Type: text/html; charset=iso-8859-1

C:\Users\user> curl.exe -I http://127.0.0.1:8081/drupal/CHANGELOG.txt
HTTP/1.1 200 OK
Date: Mon, 25 Aug 2025 16:17:42 GMT
Server: Apache/2.4.7 (Ubuntu)
Last-Modified: Wed, 27 Jul 2011 20:17:40 GMT
ETag: "e5fb-4a912bd766100"
Accept-Ranges: bytes
Content-Length: 58875
Vary: Accept-Encoding
Content-Type: text/plain

```

Step 5: Other Exposed Directories

```
curl.exe -I http://127.0.0.1:8081/phpmyadmin/
```

- The phpMyAdmin interface was accessible and disclosed session cookies, indicating the possibility of authentication bypass or brute force if credentials are weak.

```
curl.exe -I http://127.0.0.1:8081/payroll_app.php
```

```
curl.exe -I http://127.0.0.1:8081/chat/
```

- Both returned HTTP/1.1 200 OK, confirming the presence of additional web applications potentially containing business logic vulnerabilities.

```

Windows PowerShell
C:\Users\user> curl.exe -I http://127.0.0.1:8081/drupal/CHANGELOG.txt
HTTP/1.1 200 OK
Date: Mon, 25 Aug 2025 16:17:42 GMT
Server: Apache/2.4.7 (Ubuntu)
Last-Modified: Wed, 27 Jul 2011 20:17:40 GMT
ETag: "e5fb-4a912bd766100"
Accept-Ranges: bytes
Content-Length: 58875
Vary: Accept-Encoding
Content-Type: text/plain

C:\Users\user> curl.exe -I http://127.0.0.1:8081/phpmyadmin/
HTTP/1.1 200 OK
Date: Mon, 25 Aug 2025 16:23:49 GMT
Server: Apache/2.4.7 (Ubuntu)
X-Powered-By: PHP/5.4.5
Set-Cookie: phpMyAdmin=79949dfdcabefb494d1186adf9ff12bc27c481b; path=/phpmyadmin/; HttpOnly
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: private, max-age=10800, pre-check=10800
Last-Modified: Mon, 08 Apr 2013 12:06:50 GMT
Set-Cookie: pma_lang=en; expires=Wed, 24-Sep-2025 16:23:50 GMT; path=/phpmyadmin/; httponly
Set-Cookie: pma_collation_connection=utf8_general_ci; expires=Wed, 24-Sep-2025 16:23:50 GMT; path=/phpmyadmin/; httponly
Set-Cookie: pma_mcrypt_iv=6hX9C4BVH7k3D; expires=Wed, 24-Sep-2025 16:23:50 GMT; path=/phpmyadmin/; httponly
Set-Cookie: phpMyAdmin=00730adb89319b555f3918831fbd45c7907538f; path=/phpmyadmin/; HttpOnly
Content-Type: text/html; charset=utf-8

C:\Users\user> curl.exe -I http://127.0.0.1:8081/payroll_app.php
HTTP/1.1 200 OK
Date: Mon, 25 Aug 2025 16:35:41 GMT
Server: Apache/2.4.7 (Ubuntu)
X-Powered-By: PHP/5.4.5
Content-Type: text/html

C:\Users\user> curl.exe -I http://127.0.0.1:8081/chat/
HTTP/1.1 200 OK
Date: Mon, 25 Aug 2025 16:36:10 GMT
Server: Apache/2.4.7 (Ubuntu)
X-Powered-By: PHP/5.4.5
Access-Control-Allow-Origin: *
Access-Control-Allow-Credentials: true
Set-Cookie: PHPSESSID=91241c8e2055810d3ce710538ca90049; path=/
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate, post-check=0, pre-check=0
Pragma: no-cache
Content-Type: text/html

```

Conclusion

The assessment identified multiple vulnerabilities stemming from outdated components, misconfigurations, and exposed administrative interfaces.